🌐 Module 05: Web Application Penetration Testing

```
# Exercise 1: Gathering Information About a Target Website Using WhatWeb
```

Scenario

A web application is an application accessed by users over a network such as the Internet or an intranet. The term may also mean a computer software application coded in a browser-supported programming language (such as JavaScript, combined with a browser-rendered markup language like HTML) and reliant on a common web browser to render the application executable.

Web applications are popular due to the ubiquity of web browsers, and the convenience of using a web browser as a client. The ability to update and maintain web applications without distributing and installing software on potentially thousands of client computers is a key reason for their popularity, as is the inherent support for cross-platform compatibility. Common web applications include webmail, online retail sales, online auctions, wikis, and many other functions.

Web hacking refers to the exploitation of applications via HTTP which can be done by manipulating the application via its graphical web interface, tampering with the Uniform Resource Identifier (URI), or tampering with HTTP elements not contained in the URI. Methods that can be used to hack web applications are SQL Injection attacks, Cross-Site Scripting (XSS), Cross-Site Request Forgeries (CSRF), Insecure Communications, etc.

As an expert Penetration Tester and Security Administrator, you need to test web applications for cross-site scripting vulnerabilities, cookie hijacking, command injection attacks, file upload vulnerabilities, etc., and secure web applications from such attacks.

In this lab, we will use WhatWeb to identify web technologies on target websites, including content management systems (CMS), blogging platforms, analytics tools, JavaScript libraries, web servers, and embedded devices.

Objective

The objective of this lab is to help students learn how to:
- Identify the target website technologies
- Perform aggressive scans
- Log output in an XML format

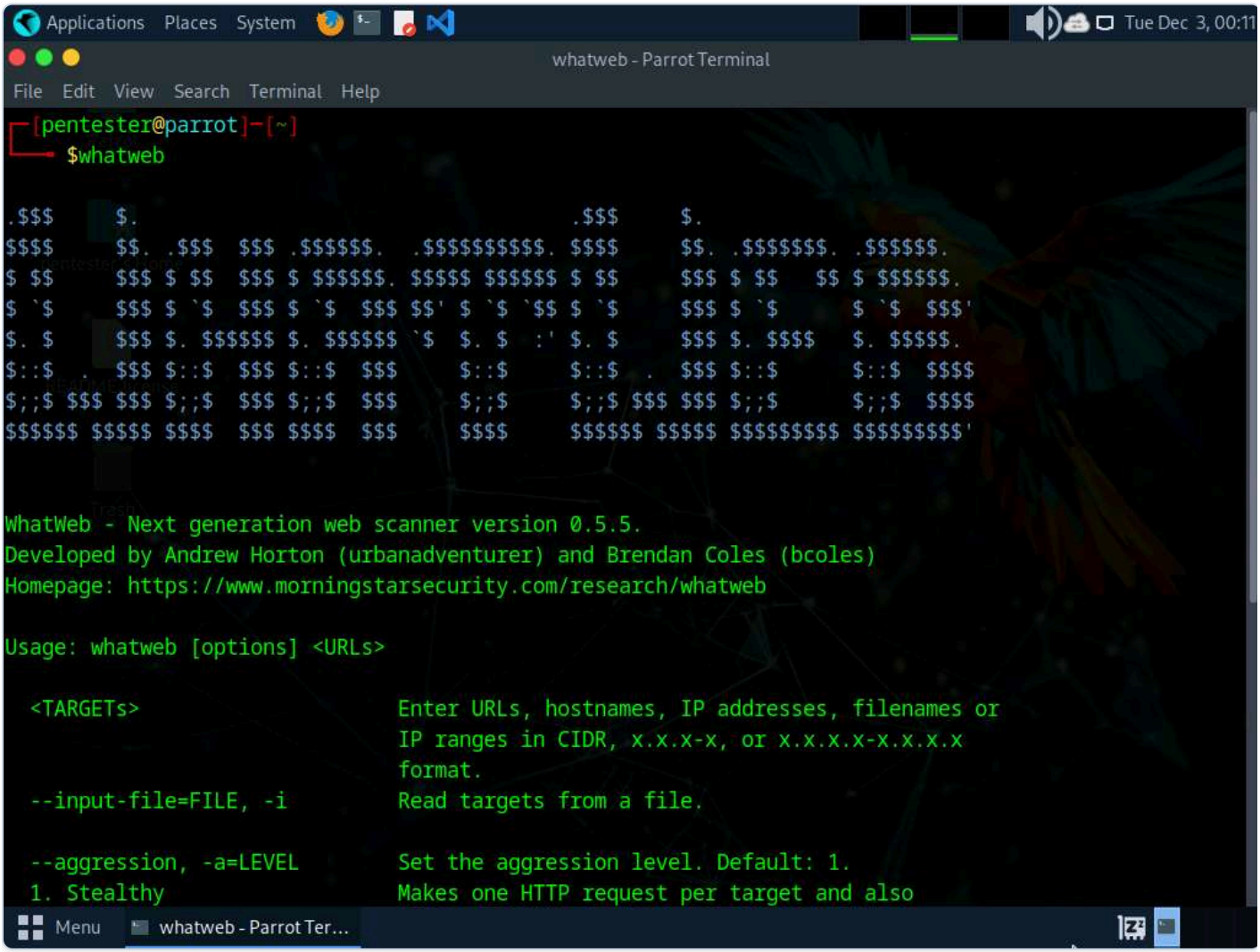
> **NOTE:** All lab manuals are accessible in the **Lab Manuals** folder located on the Desktop of the machines. Please refer to the respective lab manual if you need to copy and paste any commands or code during the lab sessions.

Task 1: Gathering Information About a Target Website Using WhatWeb

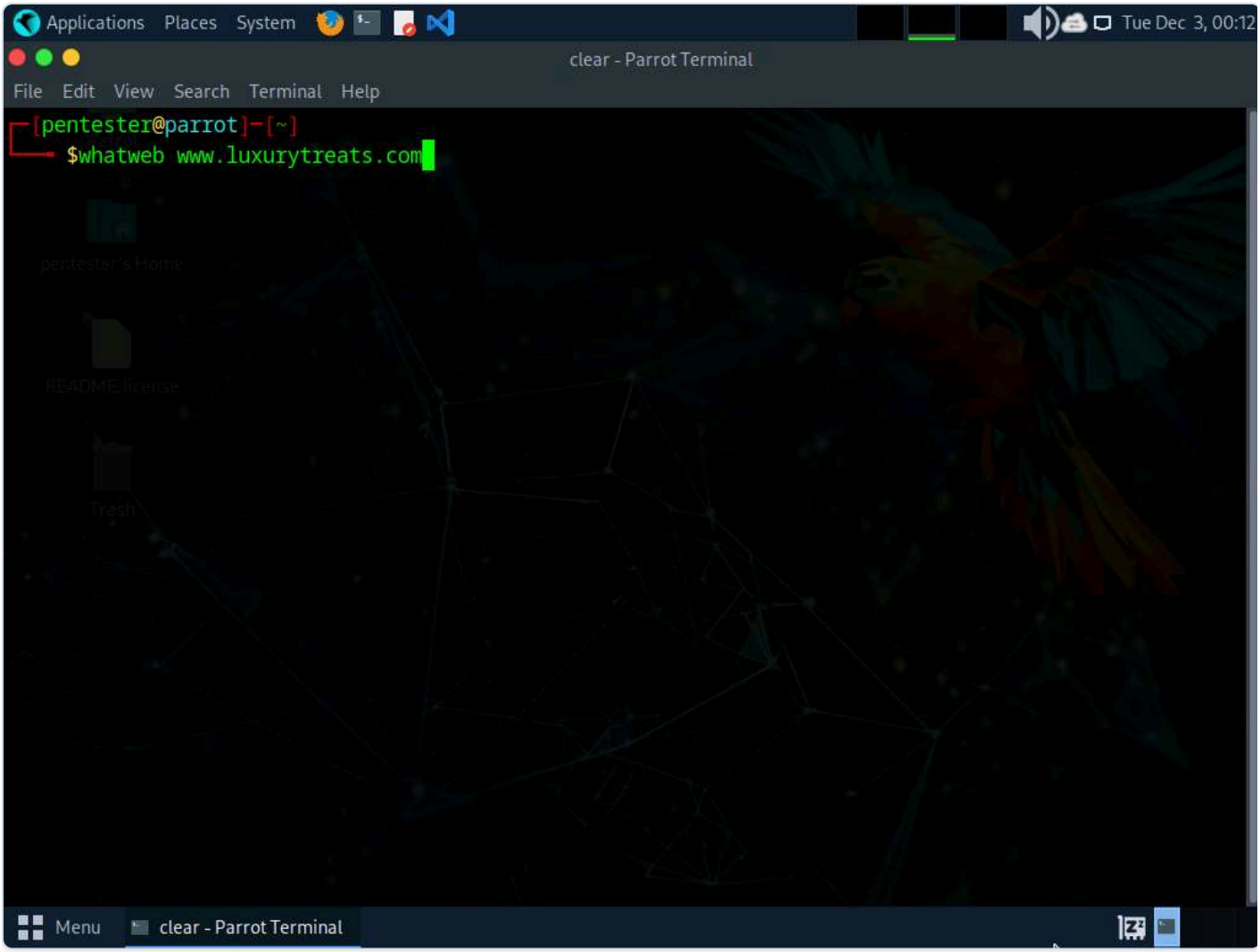
WhatWeb identifies website technologies including content management systems (CMS), blogging platforms, statistic/analytics packages, JavaScript libraries, web servers, and embedded devices. WhatWeb has over 1800 plugins, each to recognize something different. WhatWeb also identifies version numbers, email addresses, account IDs, web framework modules, SQL errors, and more.

Lab Tasks

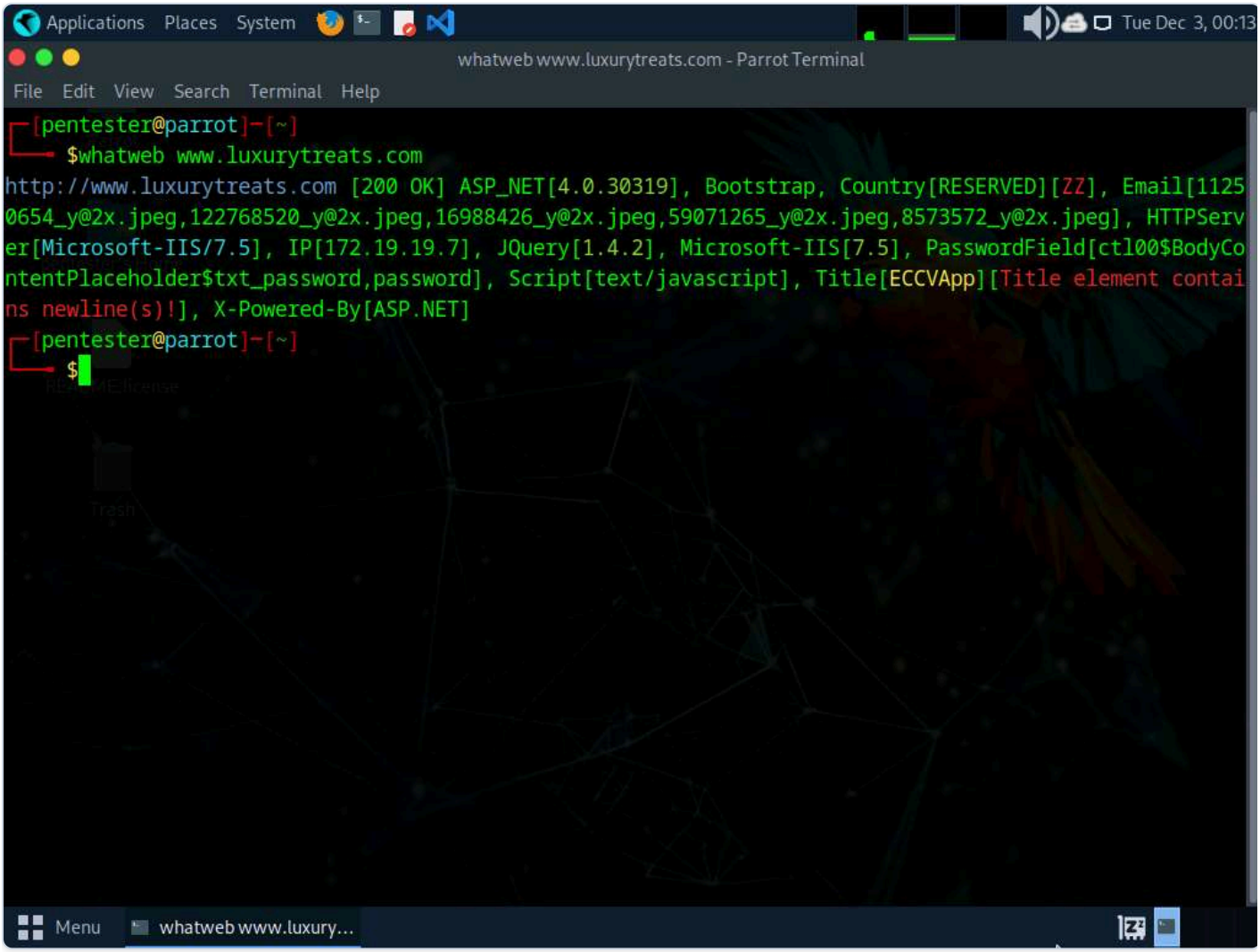
1. Click **Parrot Security**. Type **toor** in the Password field and press Enter.
2. Launch a command line terminal from the taskbar, type **whatweb**, and press Enter. It displays the list of commands used by whatweb.



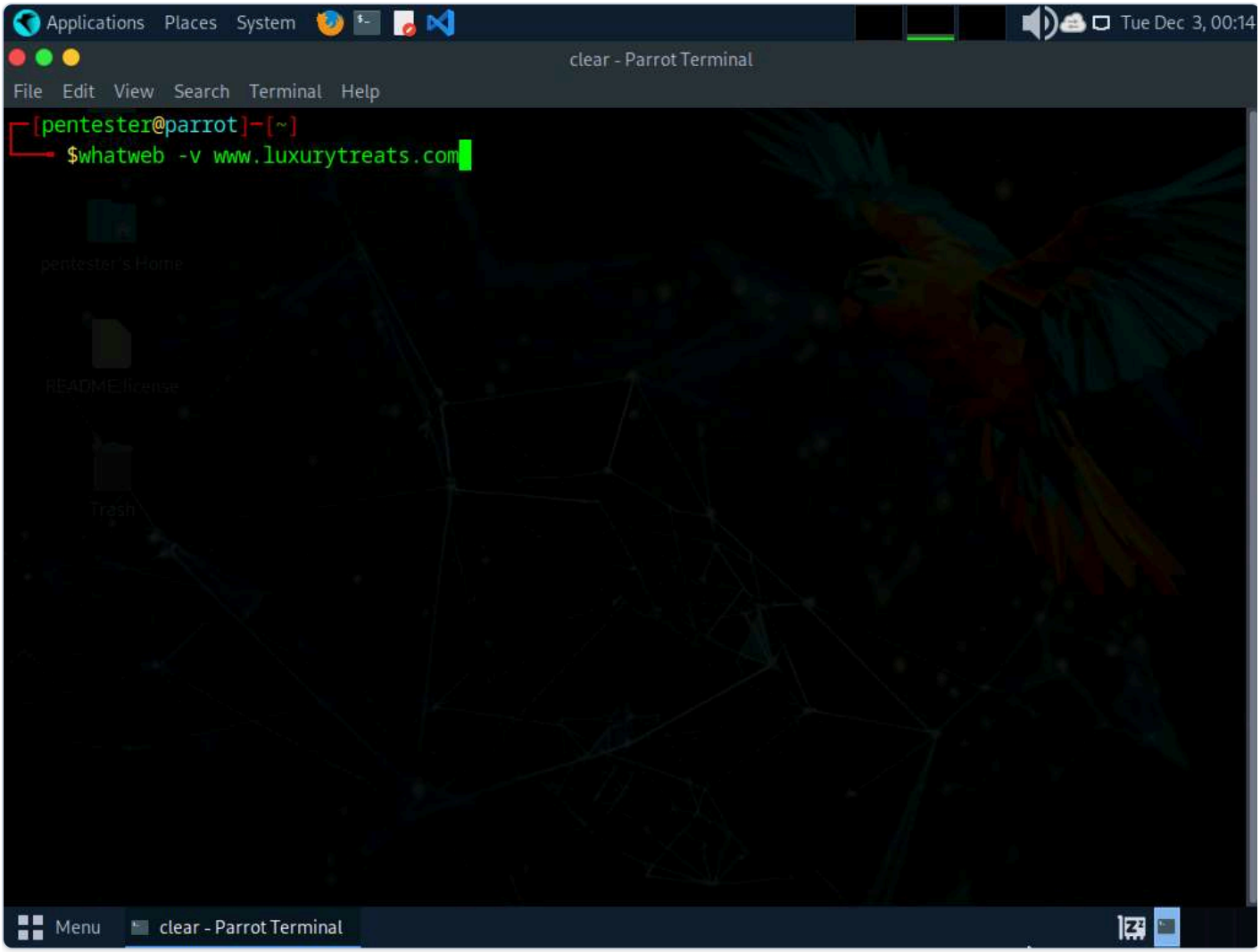
1. Assume **www.luxurytreats.com** is the target website. In this lab, you will be performing website fingerprinting on this website. Type the command **whatweb www.luxurytreats.com** and press Enter.



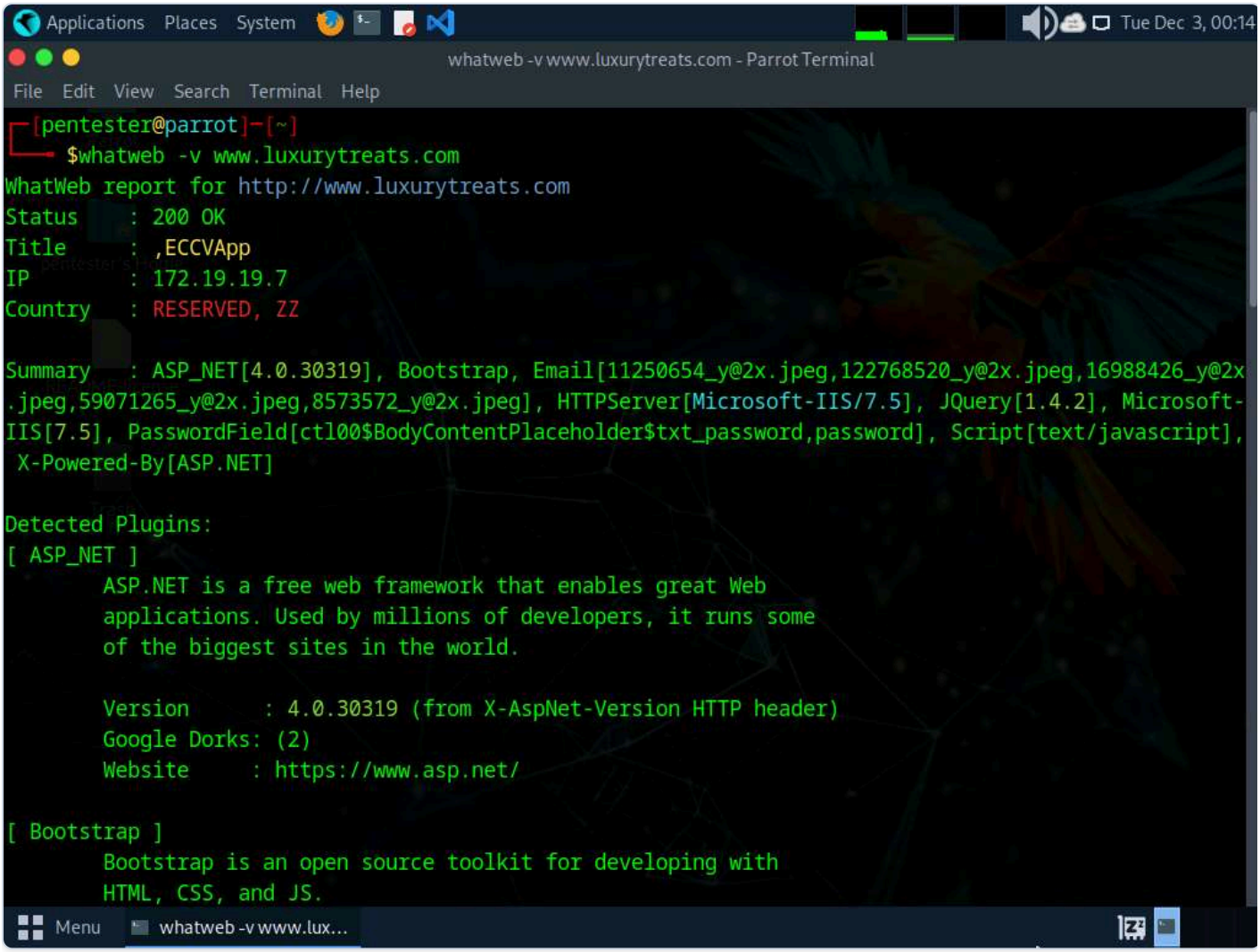
1. WhatWeb returns the luxury treats website infrastructure as shown in the screenshot.
2. *(Ignore the warning messages.)*



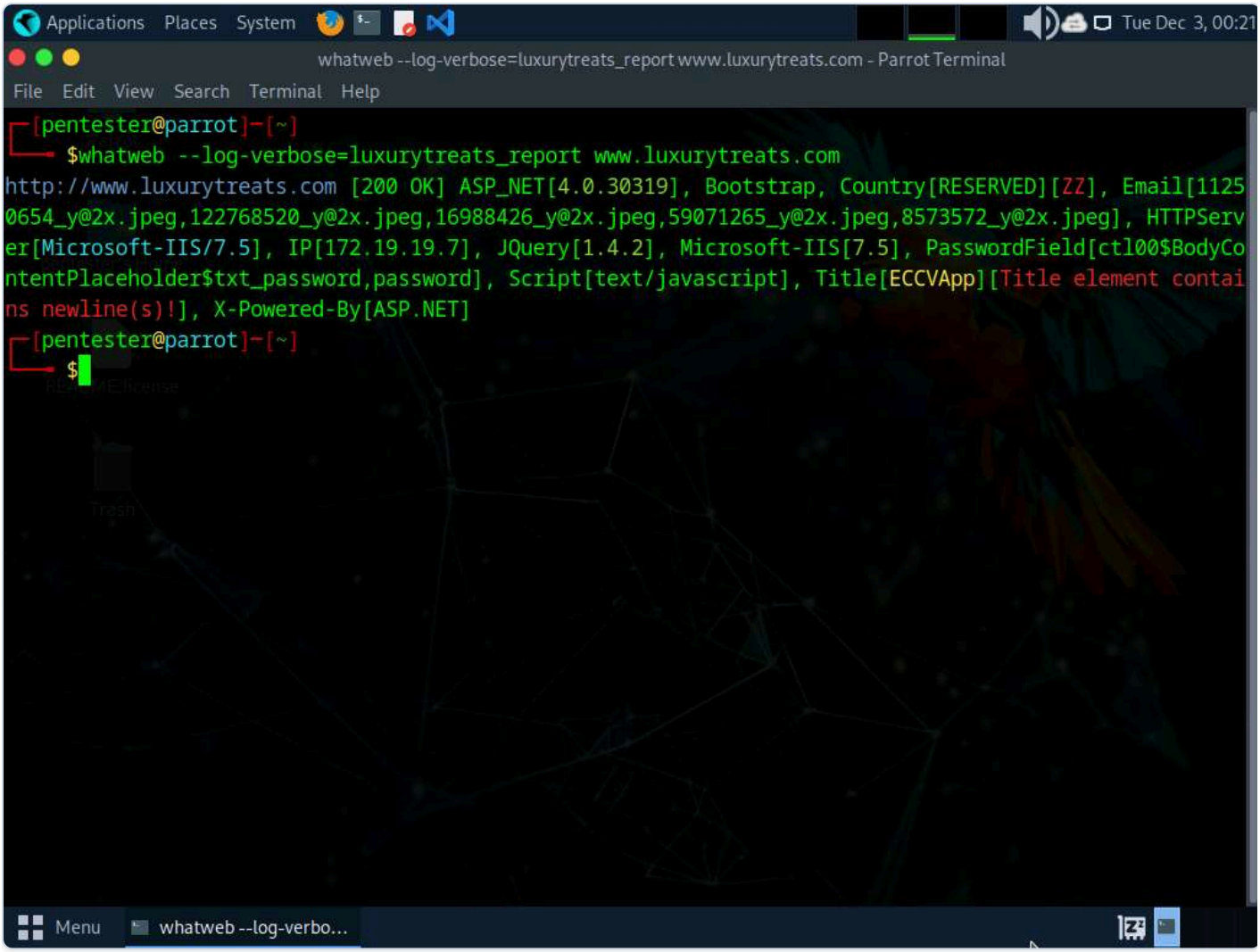
1. Since the result returned by WhatWeb is difficult to analyze, you can apply verbosity so that WhatWeb arranges the result more clearly. Type the command **whatweb -v www.luxurytreats.com** and press Enter.



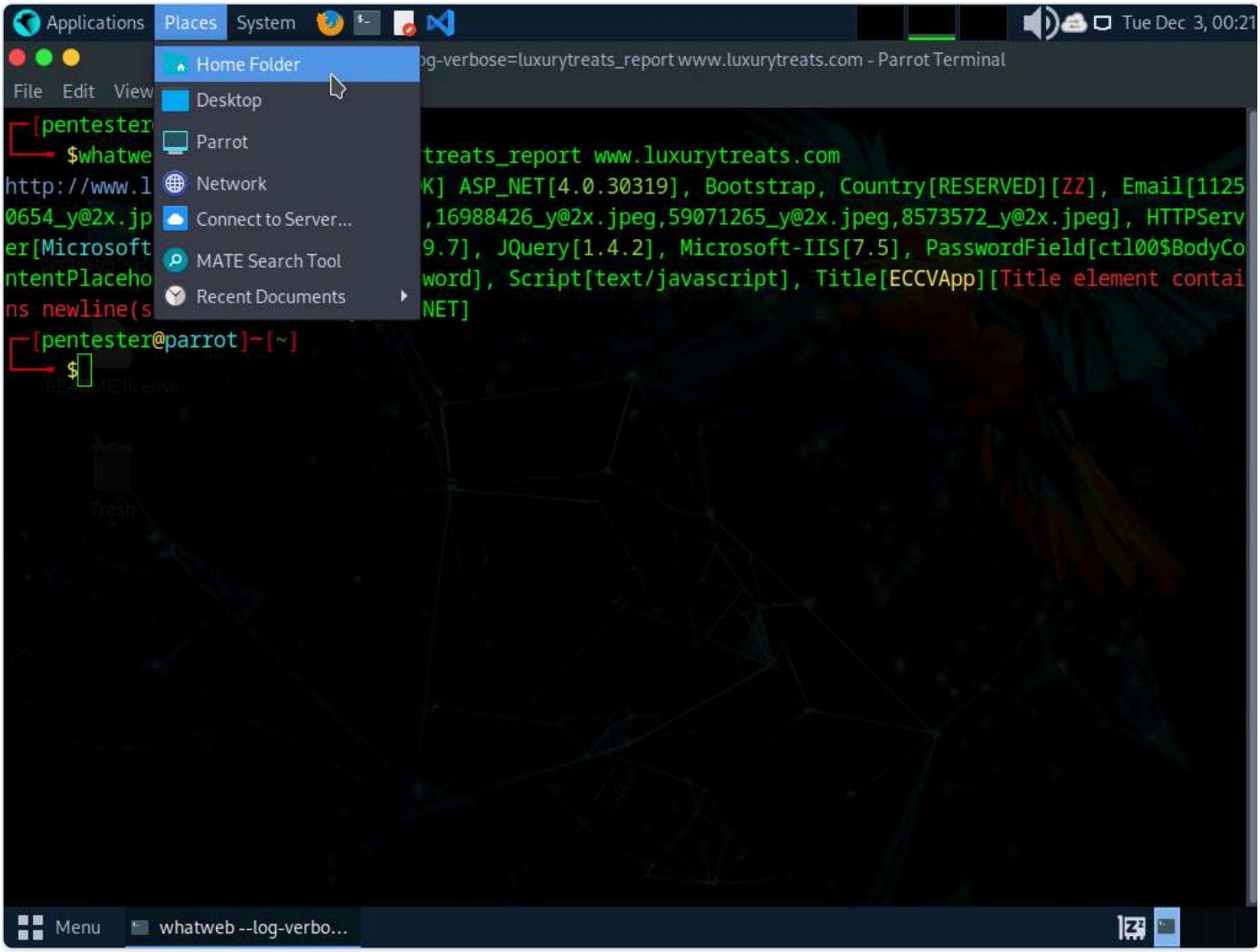
1. WhatWeb re-arranges the result in a better understandable manner as shown in the screenshot.
2. *(You may set WhatWeb in aggressive mode to obtain the version numbers of plugins used in the website.)*



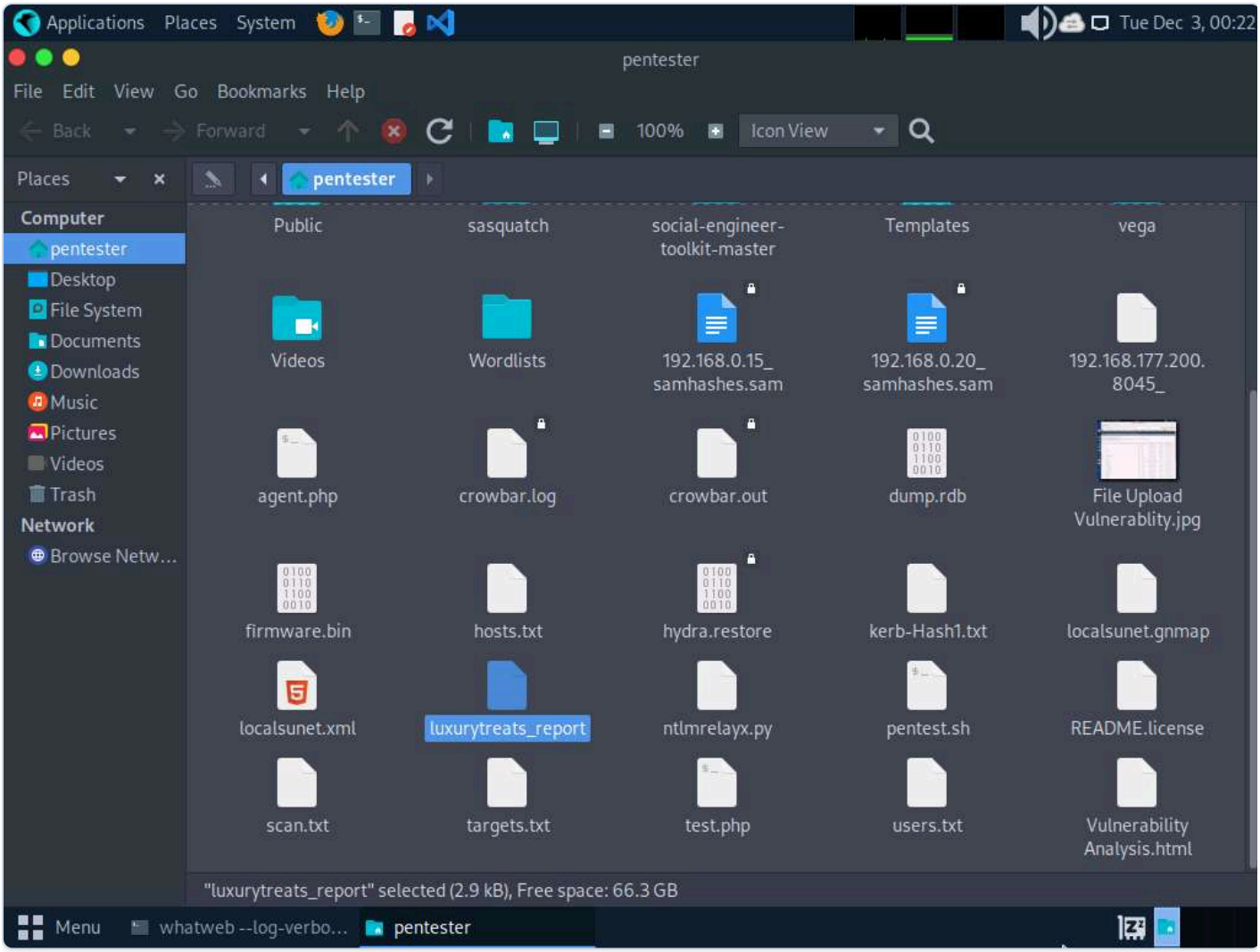
1. You can export the result returned by WhatWeb. To export the result to a text file, type the command **whatweb --log-verbose=luxurytreats_report www.luxurytreats.com** and press Enter. This will generate a report with the name **luxurytreats_report** and save this file in the home folder.



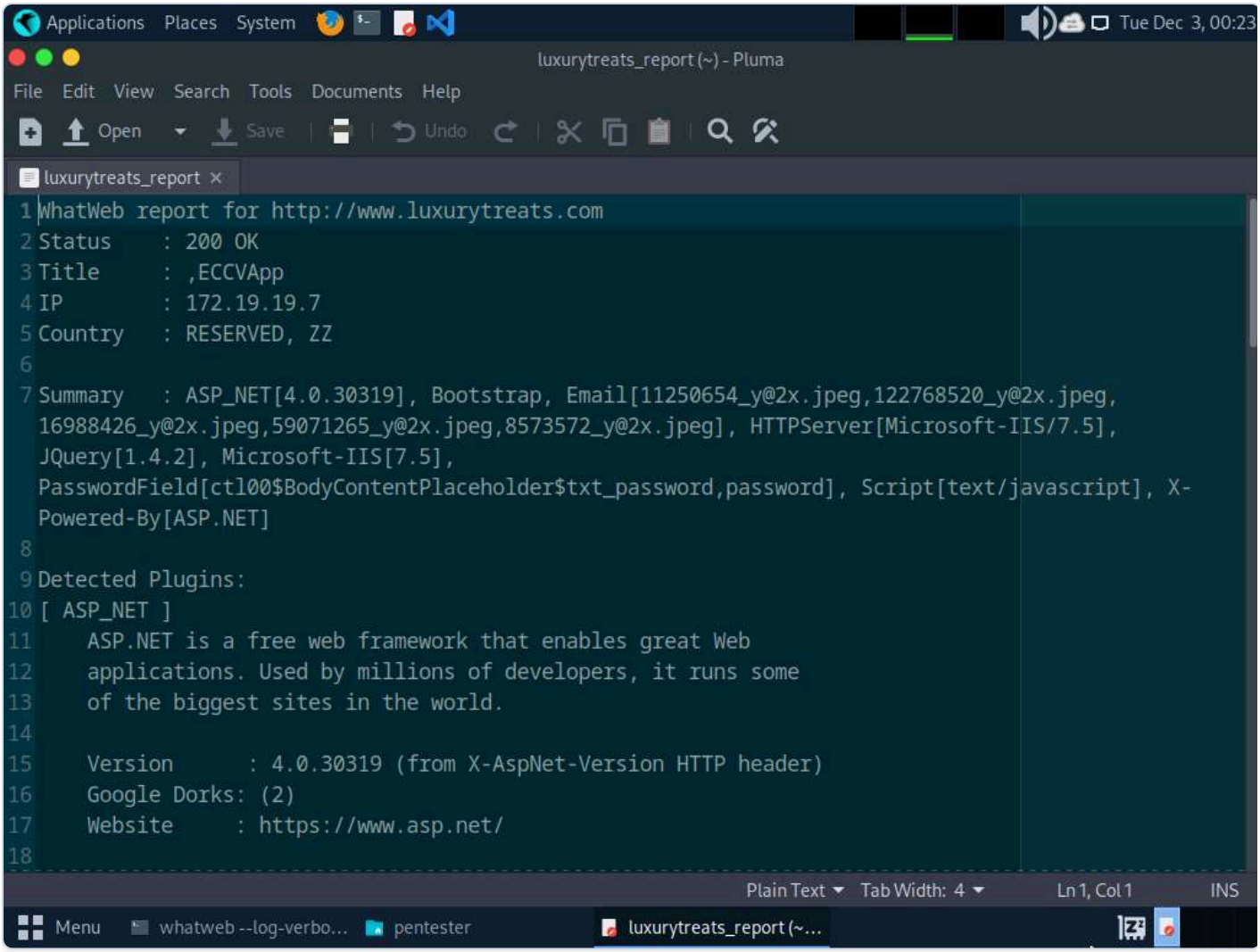
1. Navigate to the **Places** folder to find the report containing the result. To open the home folder, go to **Places** --> **Home Folder**.



1. Inside pentester folder, double-click **luxurytreats_report**.



1. The report appears in the text file as shown in the screenshot. Analyze the result to get an idea about the website infrastructure.



1. Close all the opened windows.

In this lab, you have learned how to:
- Identify the target website technologies
- Perform aggressive scans
- Log output in an XML format

IMPORTANT: ❓ **Question 5.1.1.1** On the Parrot Security machine, utilize WhatWeb to identify the web technologies used by the target, conduct aggressive scans, and log the output in XML format. Specify the IP address of the machine hosting the **www.luxurytreats.com** website. [!SUCCESS] ✅ **Answer:** **172.19.19.7**